

Phishing Detection & Awareness Report

Fatima Ilyas

15/06/2026

Table of Contents

Non-Disclosure Agreement	3
Legal Notice	3
Abstract.....	3
Introduction.....	4
Examined Emails	4
Sample-105	5
Sample 1050.....	6
Sample 1105.....	7
Sample 155.....	8
Sample 1555.....	9
Prevention & Awareness Guidelines	9
Conclusion	10
References.....	10

Non-Disclosure Agreement

All analyzed data, and findings in this report are used strictly for educational, and security awareness purposes. No sensitive, or personal information is disclosed.

Legal Notice

This report is based on sample data, and analysis techniques, and does not guarantee complete detection of all phishing techniques.

Abstract

This report presents an analysis of phishing email samples, in order to identify common indicators of malicious intent, and improve user awareness. The objective of this examination is to study email characteristics, such as sender authenticity, email header authentication results, message content, and embedded links, to determine their legitimacy. Each email is assessed, and classified based on its risk level, with clear explanations provided in simple, non-technical language. Additionally, this report outlines practical mitigation strategies, and awareness guidelines, for both individuals, and organizations, and their employees, which allows them to recognize, and avoid phishing attempts. The findings emphasize the importance of user education, as a critical defense against social engineering attacks. All evidence (screenshots) is provided in the respective “Evidence” folder, provided in the Github repository.

Introduction

Phishing is a form of social engineering attack, in which cybercriminals, otherwise referred to in this report as adversaries, attempt to deceive individuals into revealing sensitive information, such as passwords, financial data, or personal information. These attacks are typically carried out through fraudulent emails, that appear to originate from trusted sources.

Unlike traditional cyberattacks that exploit technical vulnerabilities, such as malware, brute-force, or cross-site scripting attacks, phishing primarily targets human psychology, and depends on human enforcement, creating a sense of urgency, fear, or curiosity. As a result, even well-secured systems can be compromised, if users are not adequately trained to identify suspicious communications.

This report focuses on the analysis of phishing email samples, using publicly available tools, and techniques. Key elements such as email headers, sender domains, authentication mechanisms, such as SPF, DKIM, and DMARC, and message content, are examined, to detect signs of malicious intent.

The aim of this report is not only to identify phishing indications, but also present the findings in a clear, and understandable manner, thereby, enhancing user awareness, and providing actionable guidance, to prevent phishing attacks in real-world scenarios.

Examined Emails

This report analyses, and records the findings of 5 phishing emails, from the phishing_pot database. The emails were chosen at random, to avoid ambiguity, and reduce redundancy. The sample emails' headers were analyzed using MxToolbox's header analysis tools, to dissect, and investigate all details of an email, and identify any phishing indicators. The header details are copied, then pasted, into the respective analysis tools, which then provide any identified anomalies in the email. Human inspection is also performed on each email.

Most of the samples examined do not contain crucial authentication requirements, including:

- SPF: "Sender Policy Framework", an email authentication protocol, designed to prevent email spoofing (a technique used to trick users into thinking a message came from a person, or entity, that they know, or trust [1].), by enabling the receiving mail server to check whether incoming email comes from a domain authorized by that domain's administrators [2].
- DKIM: "DomainKeys Identified Mail", an email authentication method, that uses a digital signature to let the receiver of an email know that the message was sent and authorized by the owner of a domain [3].

- DMARC: “Domain-based Message Authentication, Reporting, & Conformance”, an email authentication policy, and reporting protocol [4], that allows a sender to indicate that their messages are protected by SPF, and/or DKIM, and tells a receiver what to do if neither of those authentication methods passes, such as junk, or reject the message [5].

The emails also contain features that may be repeated.

I. Sample-105

1. Mismatched Sender: When analyzing the header information, it is discovered that the email is sent by two different domains:

From: Dewalt Power Station Unlocked <wsakt@bestshopint.com>

Return-Path: fxmvt@trlyy.com

This shows that the display name of the sender appears to be a trusted individual, or organization, as shown in the header analysis above, but the actual email address behind it does not match, or points to a suspicious, or unrelated domain. Attackers make use of this method, to trick unsuspecting users into believing the email received by them was sent by a trusted source. This removes any suspicion towards the email being malicious, and results in the user falling victim to an attack [6].

2. Delivery Information: Delivery information obtained from the email header evidences that this email does not contain a SPF, or DKIM record published, meaning it is also not DMARC compliant. This provides evidence that this email could be a potential phishing threat.

3. Misleading Information: The subject, and content of the email are as follows:

Subject: Re: You have won an Dewalt Power Station

Content:

<h2> Your chance to receive a FREE Dewalt Power Station</h2>

Firstly, the subject of the email entices the receiver, and promises them a product, or service without a price, or as a reward, that sounds too good to be true. This reward-based social engineering tactic lures the user into clicking the link provided in the email, leading to an attack. The URL provided has been shortened, which allows attackers to hide the real domain, and bypass any filters that may not allow suspicious-looking links, such as HTTP links. The subject of the email also contains a minor grammar mistake (“You have won **“an”** Dewalt Power Station, where it should actually be “You have won **“a”** Dewalt Power Station”), which also raises suspicion.

4. X-MS-Exchange-Organization-AuthAs: An email header generated by Microsoft Exchange, that defines how the sender of the message was authenticated. It is primarily used to identify whether an email originated from an internal source, a trusted organization, or an anonymous external sender. When the

header outputs the value “Anonymous”, it indicates that an incoming email originated from an unauthenticated, external source [7].

5. Risk Classification: Phishing

II. Sample-1050

1. Received Delay: As seen in screenshot “s1050_01” this email took 5 hops, meaning the email routed between different servers 5 times. Hop 2, however, is considered highly suspicious, as the transmission delay between hops 2 & 3, which is from the originating user’s server, to Microsoft’s mail protection server, is 2 hours, or approximately 8,673 seconds. This delay is considered extremely abnormal, and highly suspicious, highlighting that this email was sent from a non-professional server, and could be a part of a bulk phishing campaign queue. The blacklist column, also shown in the table, show two crosses at hop 2 & hop 5, meaning some Ips are blocked by Microsoft’s mail protection server, and by the HTTPS protocol.

2. Delivery Information: Once again, the delivery information examined for this email displays that analyzer could not find any servers by the sender’s return path, meaning it is not SPF aligned, or authenticated. Furthermore, no DKIM signature header was found, meaning this email is not DKIM aligned, or authenticated, outlining that this email is not DMARC compliant.

3. Subject, Sender Information, Header Information: The subject of this email reads, “Seus pontos Livelos expiram em breve - PROTOCOLO: 628236149”, which is Portuguese, and translates to, “Your Livelos points will expire soon. PROTOCOL: 628236149”. This pattern of urgency, along with an unknown protocol number that the user most likely does not understand, entices the user, and motivates them to “spend their points, before they expire, so as to not waste them”, which, in turn, results in the user falling victim to a phishing threat.

Furthermore, the sender information of this email also contradicts itself:

From Bradesco_infomail@bradesco.com.br

Return-Path root@ubuntu-s-1vcpu-512mb-10gb-sfo3-01

showcasing that the sender of the email, has once again, disguised themselves as a legitimate organization, so as to avoid suspicion. The return path shows an untrusted origin server, which is a cloud VPS, or virtual private machine (acts as an isolated, virtual environment, by using virtualization technology to split a single physical machine into multiple private server environments that share the resources, on a physical server, which is owned, and operated by a cloud, or web hosting provider [8].), and not a legitimate company mail server.

The X-MS-Exchange-CrossTenant-AuthAs, is a core message header used in Microsoft 365, which determines the origin, and authentication level of messages, flowing between different organizations. When the value of this header is displayed as “Anonymous”, and shown for this email, it indicates that the email passed between different Microsoft 365 organizations, without verified identity credentials.

4. Risk Classification: Phishing

III. Sample-1105

1. SPF & DKIM Information: Delivery information for this email presents that SPF, and DKIM, are not properly established, where SPF is weakly configured, and DKIM is not established at all. The DMARC record shows that no policy is established for this domain, meaning even though the policy exists, because it is not enforced, nothing happens if SPF, and DKIM authentication fails [9].

2. Sender Information: Sender information is, once again, contradictory, due to the “sender”, and “return-path” domains both being different.

3. Email Content: This email mainly focuses on user intervention, and social engineering, rather than technical threats. The contents of this email are in German, and when translated to English, show:

Subject: Personalized forecast for rapid weight loss  

 KetoXplode 



Due to extremely high demand, hurry!

The supply of KetoXplode Apple Gummies is depleted by June. Limited availability. Individual forecast for your rapid weight management. The benefits and success of the unique KETOXPLODE formula are proven by studies. Based on this information, we can calculate how much time you will need to reach your desired weight. Find out how much weight you can lose with a KETOXPLODE application and how quickly. KETOXPLODE is currently available without a prescription. Find out if KETOXPLODE is right for you personally and how much time you need to achieve your personal goals.

RECEIVE YOUR ORDER!

Go to

http://bsq2.firiri.shop/K0V6N3hPSmlhN3d5NmdrSERxaWsrLzlqYWt4c2RQU3ZreWxzVkk1dk1qYkRFeWs2N2pHbU45SzJpOE9hU1R2eTBRUzhZdXpsUGhKQ0xzWitPTzNRT3c9PQ_

or write to: 616 Corporate Way Ste. 2-9092 Valley Cottage, NY 10989

MELT FAT FAST!

WITHOUT DIET OR EXERCISE

Noticeable features of this email that cause it to gain suspicion of a phishing threat are:

- Excessive use of emoticons, not always present in professional, or even advertising and marketing emails.

- Repeated sense of urgency, “Due to extremely high demand, hurry!”, “supply depleted by June”, “limited availability”, making receivers believe they miss out on a product if they do not purchase immediately.
- Far-fetched claims, without any proper, direct evidence, extremely surface-level, vague information provided, along with no customer testimonies for the product’s validity.
- Long, undecipherable links, which regular users would be unable to determine whether they are secure, or not.
- Mailing address forwarded towards New York, when the original email was written in German, highly suspicious, could mean the email was actually sent from Germany.

4. Risk Classification: Phishing

IV. Sample-155

1. Delivery Information: This email’s SPF record shows that the policy is enabled, and aligned, but the email will be sent to the recipient regardless of whether it is malicious, or not, meaning the email will not be quarantined, or reported if it is considered malicious. Similarly, the DKIM record is aligned, and identified, but the signature of the email is not verified, thus concluding that the DMARC compliance of this email is invalid [9].

2. IP Contradictions: Under the “Headers Found” section for this email, the sender IP is shown as “77.60.117.225”, however, the x-originating-ip (records the IP address of the computer that submitted the message [10]), is said to be “37.19.195.109”, meaning the email was sent from another location, not mentioned, to the recipient.

3. Relay Information: This email went through 8 hops, from the sender to the receiver, and was blacklisted in the first, and last hop, which were with mapi (stands for messaging application programming interface, enables email communication by providing a standardized interface for a range of messaging functions [11]), and HTTPS, respectively. Another suspicious factor shown, is the large delay between hops 2, and 3, spanning 40 minutes, or around 2,413 seconds, proposing the possibility of temporary queuing, due to suspicion.

4. Email Contents: The contents of this email were fashioned to entice excitement, and quick user action, as shown:

Subject: Notice Your Bitcoin wallet has been funded

Content: As instructed, your bitcoin wallet has been funded with 51.85 BTC making a =

total of \$ 1,052,292.88 USD. Please login with the bellow details to confir=m your BTC balance.

Website : Golemcoin.net

Customer ID : 61363414

Password : bx5vbi99 Confirm your account balance.

This email, similar to previous samples, entices users to login into the website provided without checking its authenticity first, using the provided credentials as soon as possible, so as to claim this alleged offer, which is, again, too good to be true. The unnecessary “equal-to” marks scattered across the body of the email are also considered significant phishing email factors. Another factor, includes the unconfirmed, unknown user sending this email, and how this email is not sent by a reputable, known, and trusted crypto-currency related source.

5. Risk Classification: Phishing

V. Sample-1555

1. Sender Information: All three emails including the “From”, “Reply-To”, and “Return-Path” headers, are different, rising suspicion as the email is meant to be from a reputable, and well-known source, which is Microsoft.

2. Email Content: The content of the email is as follows:

Subject: Microsoft account unusual signin activity

Content: Microsoft account Unusual sign.in activity We detected something unusual about a recent sign-in to the Microsoft account Sign-in details Country/region: Russia/Moscow IP address: 103.225.77.255 Date: Sun, 15 Oct 2023 19:19:56 +0000 Platform: Windows 10 Browser: Firefox A user from Russia/Moscow just logged into your account from a new device, If this wasn't you, please report the user. If this was you, we'll trust similar activity in the future.

mailto:assistant.supp0rt.acc0unt@gmail.com?&cc=assistant.supp0rt.acc0unt@gmail.com Report The User

This email makes use of social engineering, creating a sense of urgency, and fear, making recipients act fast, without thinking, or reading over, or examining the email closely. This email is trying to pretend to be a trustworthy source, i.e., Microsoft’s account team, trying to get the user to click on a link in the email, or reply to the email to receive the recipient’s login credentials.

3. Risk Classification: Phishing

Prevention & Awareness Guidelines

Implementing effective phishing prevention guidelines enables the avoidance of a phishing attack, before it causes an unsuspecting user to fall victim to it. A layered set of technical controls, along with user awareness, significantly reduces the volume of email phishing scams that reaches users. The effects of phishing attacks can be reduced significantly by:

- Training, and educating users to recognize, and promptly respond to phishing attempts through resources like free courses, and infomercials, and encouraging them to report suspicious emails to the proper authorities.
- Ensuring users know to keep their browser, and software up-to-date, to never reply to spam emails, and to not open suspicious emails, and report it through the proper channels, teaches users how to protect themselves from social engineering phishing attacks.
- Enabling the proper protection solutions including anti-malware tools to scan devices to prevent, detect, and remove malware that affects a system through phishing attacks, email authentication protocols including SPF, DKIM, and DMARC policies, and multi-factor authentication (MFA), which adds an extra layer of security by requiring a second form of verification, such as a code sent to a mobile device, to access sensitive accounts.
- Checking for domain abuse, where attackers disguise, and abuse brand, and domain names, for example, “amaz0n.com, go0gle.com”. Frequent checking of domain name abuse needs to be implemented by security teams, and takedown requests to the domain service provider needs to be issued when malicious domains are found [12].

Conclusion

This report analyzed 5 phishing email samples, obtained from the phishing_pot database, using both automated tools, and manual inspection techniques. Across all examined samples, consistent patterns of malicious behavior were identified, including inconsistent sender information, lack of appropriate email authentication, including SPF, DKIM, and DMARC policies, suspicious routing paths, and the use of social engineering tactics, such as urgency, fear, and reward-based bait. The findings demonstrate that phishing attacks do not solely rely on technical exploitation, but rather on manipulating user behavior, and trust.

The examination highlights the critical importance of multi-layered defense strategy. Technical controls, including properly enforced authentication protocols, and anti-malware solutions, must be combined with continuous user education, and awareness. Users must be trained to recognize common phishing indicators, such as suspicious links, inconsistent sender details, and emotionally manipulative language.

To conclude, phishing remains a highly effective, and evolving threat, due to its reliance on human factors. Strengthening both technical defenses, and user awareness, is essential, in order to mitigate the risks associated with phishing attacks, and improving overall cybersecurity resilience.

References

1. Proofpoint. “What Is SPF? - Sender Policy Framework Defined | Proofpoint US.” Proofpoint, 28 July 2021, www.proofpoint.com/us/threat-reference/spf.

2. Proofpoint. "Email Spoofing – What It Is, How It Works & More | Proofpoint US." Proofpoint, 26 Feb. 2021, www.proofpoint.com/us/threat-reference/email-spoofing.
3. mimecast. "What Is DKIM & DKIM Record and Why Is It Important?" Mimecast, 2024, www.mimecast.com/content/dkim/.
4. DMARC. "Dmarc.org – Domain Message Authentication Reporting & Conformance." Dmarc.org, 2015, dmarc.org/.
5. "FAQ - DMARC Wiki." Dmarc.org, dmarc.org/wiki/FAQ#How_does_DMARC_work.2C_briefly.2C_and_in_non-technical_terms.3F.
6. "The 10 Phishing Red Flags Your Employees Need to Know (2024) - Hoxhunt." Hoxhunt.com, 2024, hoxhunt.com/blog/phishing-red-flags.
7. SEPPmail GmbH. "MS 365: Email Direction Is Sometimes Recognised Incorrectly in Parallel Connected M365 Environments." Seppmail.com, 2023, docs.seppmail.com/en/09_ht_wrong_mail_direction_m365_parallel.html.
8. "What Is a Virtual Private Server (VPS)?" Google Cloud, cloud.google.com/learn/what-is-a-virtual-private-server.
9. "PowerDMARC." PowerDMARC, 8 Jan. 2025, powerdmarc.com/what-is-dmarc-policy/.
10. Jean-François Carlot. Top' Actuel Droit Des Assurances. Hachette Éducation, 26 Feb. 2014.
11. "MAPI - a Guide to Messaging Application Programming | Lenovo US." Lenovo.com, 2021, www.lenovo.com/us/en/glossary/what-is-mapi/?orgRef=https%253A%252F%252Fwww.google.com%252F&srsId=AfmBOoogGayDlf4oTozhCrBdtGGoNsWoJMBKJ3b7IJg_pBuJ980SejwI.
12. Lenaerts-Bergmans, Bart. "What Is Phishing? Techniques and Prevention | CrowdStrike." Crowdstrike.com, 24 Oct. 2024, www.crowdstrike.com/en-us/cybersecurity-101/social-engineering/phishing-attack/.
13. Phishing Pot https://github.com/rf-peixoto/phishing_pot/tree/main